



Federal Office
for Information Security

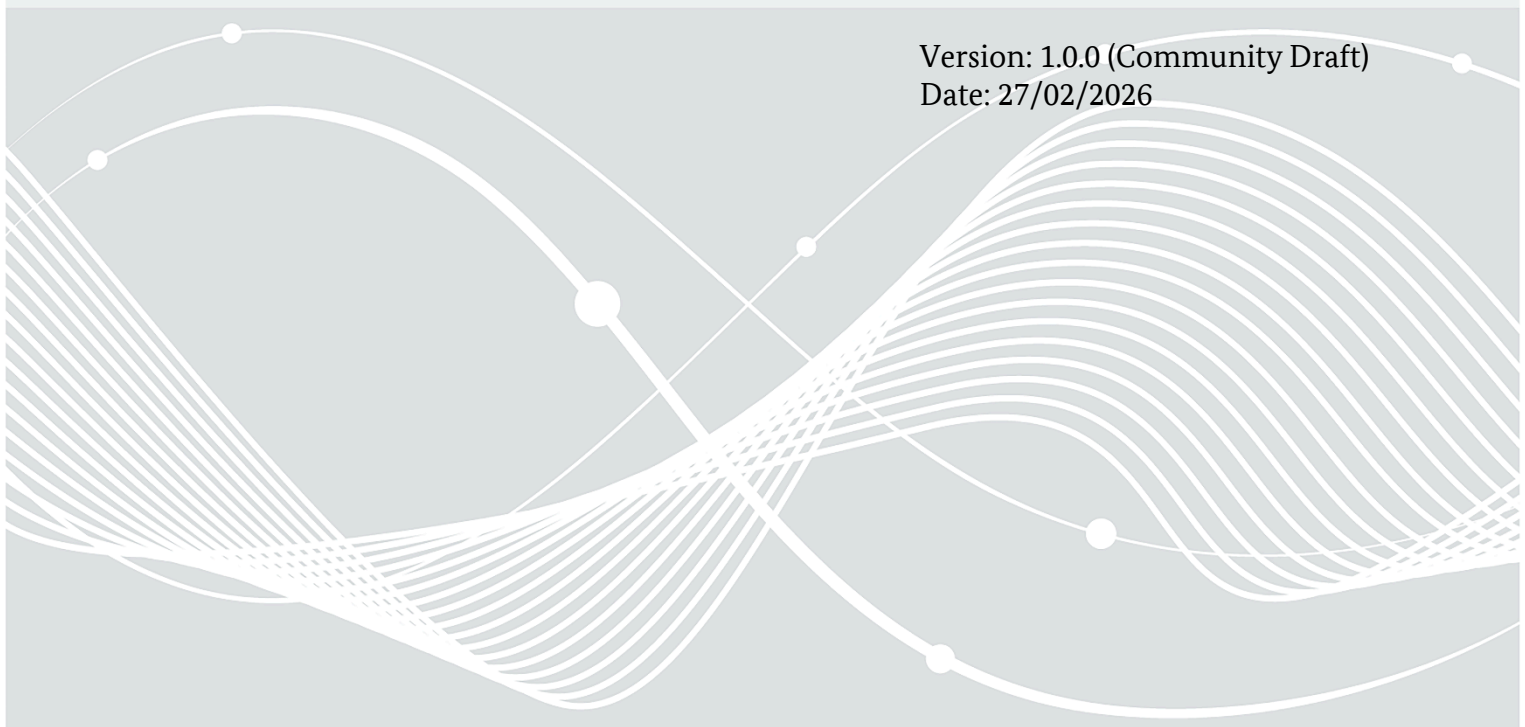
Technical Guideline TR-03183-H

Cyber Resilience Requirements for Manufacturers and Products

Conformity based on full quality assurance
(Module H)

Feedback to tr-03183@bsi.bund.de until 31 March 2026

Version: 1.0.0 (Community Draft)
Date: 27/02/2026



Document History

Table 1: Document History

Date	Header	Description
27/02/2026	Federal Office for Information Security (BSI)	Version 1.0.0 (Community Draft)

Federal Office for Information Security
P.O. Box 20 03 63
53133 Bonn
E-Mail: TR03183@bsi.bund.de
Internet: <https://bsi.bund.de/dok/TR-03183-en>
© Federal Office for Information Security 2023 - 2025

Table of Contents

1	Introduction.....	4
2	Scope.....	5
3	Normative references.....	7
4	Terms and definitions.....	8
5	CRA-specific requirements related to ISO/IEC 27001:2022.....	9
5.1	General.....	9
5.2	Applicability of cybersecurity controls for products.....	9
5.3	CRA 4.2 Understanding the needs and expectations of interested parties.....	9
5.4	CRA 4.3 Determining the scope of the information security management system.....	9
5.5	CRA 5.2 Policy.....	10
5.6	CRA 6.1.2 Information security risk assessment.....	10
5.7	CRA 6.1.3 Information security risk treatment.....	11
5.8	CRA 7.4 Communication.....	11
5.9	CRA 7.5.1 Documented information - General.....	12
5.10	CRA 8.1 Operational planning and control.....	12
6	CRA-specific guidance related to ISO/IEC 27002.....	13
6.1	General.....	13
6.2	CRA 8.8 Management of technical vulnerabilities.....	13
6.3	CRA 8.25 Secure development life cycle.....	13
7	Annex A: Essential cybersecurity requirements.....	15
7.1	A.1 Essential cybersecurity requirements Part I.....	15
7.2	A.2 Essential cybersecurity requirements Part II.....	17
8	Annex B: Application of TR-03183-1.....	20

1 Introduction

This document describes a way to demonstrate compliance with the essential cyber resilience requirements of the EU Regulation 2024/2847 "Cyber Resilience Act" (CRA) using an ISO 27001 compliant ISMS.

This document will refine and extend the requirements of the ISO 27001 to include the design, development or production as well as vulnerability handling of products with digital elements (PwDE) as well as part thereof subject to the CRA.

This document is NOT a new management system standard independent of ISO/IEC 27001, but rather

- a. specifies CRA-specific requirements that are composed of refinements of and additions to requirements in ISO/IEC 27001 based on the essential cybersecurity requirements of the Cyber Resilience Act as set out in Annex A.
- b. specifies CRA-specific guidance that supports additions to and/or modifications of ISO/IEC 27002 (see Clause 6).

2 Scope

The scope of this document is the application of the requirements of ISO 27001:2022 and additional requirements for products under the Scope of the CRA.

This document addresses organizations developing or manufacturing PwDE or having PwDE designed, developed or manufactured, and marketing them under their name or trademark, i.e. the manufacturer (CRA Article 3 Point 13). This applies even if the product is not directly placed on the European market by the manufacturer itself.

As show in Figure 1, the scope of the ISMS includes the business services for placing a PwDE on the market as well as the business services for providing a remote data processing solutions (RPDS) as part of the PwDE.

Note: The specific definition of RDPS belonging to a PwDE relies on additional guidance by the European Commission. For the meantime this guideline will assume that RDPS entails at least software designed, developed and operated by or on behalf of the manufacturer, whose absence would prevent the product with digital elements from performing one of its function. (Article 3 Point 2 CRA)

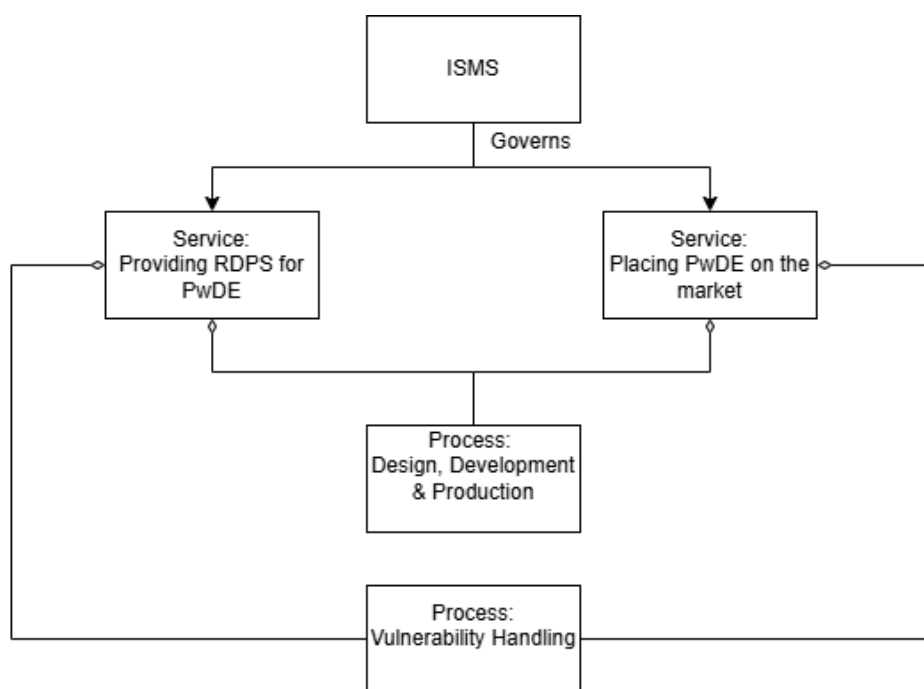


Figure 1. Scope of ISMS for PwDE

Note: Generally, the RDPS is a part of the PwDE and therefore subject to the same requirements under the CRA. For the sake of clarity, this document differentiates between the two as the RDPS stays under the control of the manufacturer and the PwDE placed on the market is operated by a third party user. Preferably both parts follow the same processes.

Both of the above mentioned services include design, development or production as well as vulnerability handling processes in relation to their respective output.

For the mitigation of cybersecurity risks to the user or society, the design, development and production as well as the vulnerability handling processes, the requirements of ISO/IEC 27001:2022 apply.

Additional requirements will be applied for the design, development and production as well as the vulnerability handling processes for PwDE in scope with regards to the essential cybersecurity requirements set out in Annex A of this document following the objective to provide an appropriate level of cybersecurity with regard to affected third-parties.

3 Normative references

ISO/IEC 27000, Information technology – Security techniques – Information security management systems – Overview and vocabulary

ISO/IEC 27001, Information security, cybersecurity and privacy protection – Information security controls

ISO/IEC 27002, Information security, cybersecurity and privacy protection – Information security management systems – Requirements

TR-03183-1: Cyber Resilience Requirements for Manufacturers and Products

4 Terms and definitions

For the purposes of this document, the terms and definitions given in ISO/IEC 27000 as well as the definitions in Article 3 of the CRA apply.

Additional definitions used in this document:

Affected third-party

User, society and other third-parties potentially adversely affected by a cybersecurity risk of the PwDE in scope.

Compliant specification

Normative documents specifying the essential cybersecurity requirements of the CRA which are compliant to assumptions set out in this document and usable in the scope of module H.

Design, development and production process

Processes of the manufacturer resulting in placing a PwDE on the market or performing modifications to product afterwards including all relevant activities from initial concept to final product as well as quality assurance processes.

PwDE in scope

PwDE, type of PwDE or multiple types of PwDE developed or manufactured by the manufacturer or designed, developed or manufactured on behalf of the manufacturer, and marketed under the name or trademark of the manufacturer, which is subject to the processes set out in this document to demonstrate conformity.

Vulnerability handling process

The process of identifying, evaluating, treating and disclosing vulnerabilities in a PwDE during its defined support period. Treatment includes mitigation or elimination of the vulnerability through appropriate measures such as patches, updates or workarounds and might result in a modification of the PwDE via the design, development and production process.

5 CRA-specific requirements related to ISO/IEC 27001:2022

5.1 General

All requirements from ISO/IEC 27001:2022, Clauses 4 to 10, that do not appear below shall apply unchanged.

5.2 Applicability of cybersecurity controls for products

This document refers to compliant specifications for specific product types and use cases. These specifications refine the essential cybersecurity requirements set out in CRA Annex I or part thereof and follow certain assumptions given in this document.

Compliant specifications are

1. Preferably harmonised European standards (hEN) cited for presumption of conformity in their respective scope
2. Otherwise the Technical Guideline BSI TR-03183-1 including compliant profiles if no appropriate hEN exists or the appropriate hEN does not fulfil the assumptions set out in this guideline

Essential cybersecurity requirements or part thereof should not be interpreted directly without compliant specification.

5.3 CRA 4.2 Understanding the needs and expectations of interested parties

ISO/IEC 27001:2022, 4.2 is refined as follows.

1. Interested parties that are relevant to the information security management system shall at least include the manufacturer and affected third-parties;
2. Relevant requirements of these interested parties, include at least the requirement for the manufacturer for compliance with the CRA and the affected third-parties expectations regarding an appropriate level of cybersecurity based on the intended purpose and reasonably foreseeable use of the PwDE in Scope;
3. Requirements addressed through the information security management system include at least the requirement of the manufacturer for compliance with the CRA and the affected third-parties expectations regarding an appropriate level of cybersecurity for the intended purpose and reasonably foreseeable use of the PwDE in Scope;

5.4 CRA 4.3 Determining the scope of the information security management system

ISO/IEC 27001:2022, 4.2 is refined as follows.

The scope of the information security management system must include at least the PwDE in Scope to be covered by the ISMS as well as the following services related to the PwDE in Scope:

1. Placing a PwDE on the market consisting of:
 - a. The design, development and production process of the PwDE in scope
 - b. The vulnerability handling process of the PwDE in scope required to maintain the PwDE operated by a third-party user during its defined support period
2. Providing RDPS of the PwDE:
 - a. The design and development process resulting in providing an RDPS as part of the PwDE in scope
 - b. The vulnerability handling process of the RDPS as part of PwDE required to maintain the RDPS operated by the manufacturer or on behalf of the manufacturer during its defined support period

Note: The processes in scope of this document can handle multiple types of PwDE.

5.5 CRA 5.2 Policy

ISO/IEC 27001:2022, 5.2 is refined as follows.

1. information security objectives shall include at least
 - a. that the PwDE in scope ensures an appropriate level of cybersecurity based on the risks as set out in Annex I Part I CRA.
 - b. that the manufacturer fulfils the vulnerability handling requirements as set out in Annex I Part II CRA during the defined support period of PwDE in scope.

5.6 CRA 6.1.2 Information security risk assessment

ISO/IEC 27001:2022, 6.1.2. is refined as follows.

The risk acceptance criteria as set out in 6.1.2. a) 1) shall include the following criteria:

1. Non-compliance with the CRA is not acceptable
2. Risks to affected third-parties can only be accepted if an appropriate level of cybersecurity based on the intended purpose and reasonably foreseeable use of the PwDE in scope is ensured.

Assumption: This document assumes that a compliant specification defines, at least implicitly, appropriate acceptance criteria for risks of affected third-parties in their respective scope. If a harmonized European Standard (hEN) is cited for presumption of conformity it is assumed that the regulator accepts that all residual risks not addressed can be accepted for the scope of the hES until further notice. TR-03183-1 defines general risk acceptance criteria and applies as described in Annex B.

The identified risks as set out in 6.1.2. c) shall include at least:

1. the risks of a non-CRA-compliant PwDE
2. all relevant cybersecurity risks with impact on affected third-parties resulting from loss of confidentiality, integrity and availability of the PwDEs functionality or the data handled by the PwDE based on the intended purpose and reasonably foreseeable use.

The risk owner as set out in 6.1.2. c) for non-compliance and risks with impact to affected third-parties is the manufacturer

The analysis of the information security risks as set out in 6.1.2. d), shall take into account the impact and likelihood of an incident based on the intended purpose and reasonably foreseeable use of the PwDE.

Assumption: This document assumes that a reproducible identification and analysis strategy for risks to affected third-parties is set out in a compliant specification for Annex I Part I CRA, especially hEN cited for presumption of conformity. TR-03183-1 applies as described in Annex B.

5.7 CRA 6.1.3 Information security risk treatment

In addition to ISO/IEC 27001, 6.1.3 the following CRA-specific requirements apply:

6.1.3 a-1) In addition to 6.1.3. a) the information security risk treatment options shall include a secure development lifecycle as part of the design, development and production process ensuring an appropriate level of cybersecurity based on the risks assessed in 6.1.2 in order to fulfil the applicable requirements of Annex A.1.

6.1.3 a-2) In addition to 6.1.3. a) the information security risk treatment options shall include management of technical vulnerabilities as part of the vulnerability handling process of the manufacturer in order to fulfil all requirements of Annex A.2.

6.1.3 c-1) In addition to 6.1.3. c) shall compare the controls of the PwDE in scope implemented as part of the secure development lifecycle in 6.1.3 a-1) above with those in Annex A.1 and based on the risk verify that no necessary controls have been omitted.

6.1.3 d-1) The produced statement of applicability shall also include appropriate risk based justification for omitting any controls in Annex A.1 during the secure development lifecycle of the PwDE in scope based on the risk acceptance criteria defined in 6.1.2 a) above.

Assumption: This document assumes that a compliant specification for Annex I Part I CRA refines applicable essential cybersecurity requirements with specific controls and potentially excludes some essential cybersecurity requirements using a risk-based justification. TR-03183-1 applies as described in Annex B.

5.8 CRA 7.4 Communication

ISO/IEC 27001:2022, 7.4. is refined as follows.

The determined need for external communication shall at least include communication with users of the PwDE in scope providing at least the necessary information set out in Annex II CRA.

The determined need for external communication shall take into account the capabilities and expectations of the user of the PwDE in scope.

Note: User information can be part of a control set out in 6.1.3 necessary to mitigate identified risks to an acceptable level. This is important as manufacturers can not ensure appropriate competence of third-party users of the PwDE. The competency required for parts of the PwDE operated by the manufacturer or on behalf of the manufacturer, i.e. RDPS, can be provided through internal communication.

Assumption: This document assumes that a compliant specification for Annex I Part I CRA refines the requirements for user documentation if required for appropriate risk treatment through user documentation. TR-03183-1 can apply as described in Annex B.

Note: The manufacturer may take into account different user groups if different aspects of the PwDE are subject to different user groups, e.g. end-user, administrator or integrator.

5.9 CRA 7.5.1 Documented information - General

In addition to ISO/IEC 27001:2022 7.5.1 the following CRA-specific requirements apply:

7.5.1-1) The manufacturer's information security management system shall include documented information according to ANNEX VII CRA for the PwDE in scope where applicable.

7.5.1-2) The manufacturer's information security management system shall include documented information according to ANNEX VIII 3.2 for the CRA.

7.5.1-3) Documented information as required by 7.5.1-2 and 7.5.1-3 shall be truthful, correct, current and sufficiently complete to monitor and evaluate the design, development and production process of the PwDE in scope as well as the vulnerability handling processes of the manufacturer to demonstrate CRA compliance.

5.10 CRA 8.1 Operational planning and control

ISO/IEC 27001:2022, 7.4. is refined as follows.

The criteria for the design, development and production process of the PwDE shall include that the secure development lifecycle as defined in 6.1.3 b-1) are implemented or otherwise realized as designed and appropriately verified based on the associated risk before placing a PwDE on the market.

The criteria for the vulnerability handling process of the manufacturer includes that the controls as defined in 6.1.3 b-2) are implemented by the manufacturer as part of the vulnerability handling process during the defined support period of the PwDE in scope.

Assumption: This document assumes that any compliant specification of Annex I Part I CRA is either concise enough or gives additional guidance to verify that controls determined in 6.1.3 b-1) are properly implemented by the PwDE in scope. Furthermore this document assumes that any compliant specification for Annex II CRA is either concise enough or gives additional guidance to verify that the controls determined in 6.1.3. b-2) are provided by the manufacturer as part of the vulnerability handling process. TR-03183-1 applies as described in Annex B.

6 CRA-specific guidance related to ISO/IEC 27002

6.1 General

All clauses, control objectives, controls, implementation guidance and other information from ISO/IEC 27002 that do not appear below apply unchanged.

6.2 CRA 8.8 Management of technical vulnerabilities

Control 8.8 is modified as follows

Control

Information about technical vulnerabilities of **PwDEs** should be obtained, the **PwDEs** exposure to such vulnerabilities should be evaluated and appropriate measures should be taken.

Purpose

To prevent exploitation of technical vulnerabilities.

Guidance

To identify, evaluate, communicate and take appropriate measures to address technical vulnerabilities a compliant specification for Annex I Part II CRA should be applied for the management of technical vulnerabilities.

[...]

6.3 CRA 8.25 Secure development life cycle

Control 8.25 is modified as follows

Control

Rules for the secure development of **PwDE** should be established and applied.

Purpose

To ensure information security is designed and implemented within the secure development life cycle of **PwDE**.

Guidance

Secure development is a requirement to build up a secure **PwDE**.

To achieve this, the following aspects should be considered:

[...]

- c. security requirements in the specification and design phase including

1. if not already done in 6.1.2, a product specific risk assessment based on the risk for affected third-parties assessed in CRA 6.1.2;
 2. product specific controls able to provide an appropriate level of cybersecurity based on the risks of the PwDE in scope (Annex I Part I 1 CRA) as well as to fulfil the applicable cybersecurity requirements of Annex I Part I 2 CRA using one or more appropriate compliant specification for Annex I Part I.
- d. security checkpoints in projects ensuring that
1. the PwDE in scope is not placed on the market without fulfilling the security requirements
 2. changes to the PwDE in scope already placed on the market maintain the security requirements
- e. system and security testing, such as regression testing, code scan and penetration tests able to verify that
1. the security requirements are fulfilled before placing the PwDE in scope on the market
 2. the security requirements are upheld during the defined support period of the PwDE in scope

[...]

7 Annex A: Essential cybersecurity requirements

7.1 A.1 Essential cybersecurity requirements Part I

Table 1: Annex I Part I Requirement 1

ID	CRA Reference	Requirement
ER.0	Annex I Part I 1	Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.

On the basis of the cybersecurity risk assessment referred to in Article 13(2) and where applicable, products with digital elements shall:

Table 2: Annex I Part I Requirement 2

ID	CRA Reference	Requirement
ER.1	Annex I Part I 2 Point a	be made available on the market without known exploitable vulnerabilities;
ER.2	Annex I Part I 2 Point b	be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements
ER.3a	Annex I Part I 2 Point b	including the possibility to reset the product to its original state;
ER.4	Annex I Part I 2 Point c	ensure that vulnerabilities can be addressed through security updates,
ER.4a	Annex I Part I 2 Point c	including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting,
ER.4b	Annex I Part I 2 Point c	with a clear and easy-to-use opt-out mechanism,
ER.4c	Annex I Part I 2 Point c	through the notification of available updates to users,
ER.4d	Annex I Part I 2 Point c	and the option to temporarily postpone them;

ID	CRA Reference	Requirement
ER.5	Annex I Part I 2 Point d	ensure protection from unauthorised access by appropriate control mechanisms,
ER.5a	Annex I Part I 2 Point d	including but not limited to authentication, identity or access management systems,
ER.5b	Annex I Part I 2 Point d	and report on possible unauthorised access;
ER.6	Annex I Part I 2 Point e	protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;
ER.7	Annex I Part I 2 Point f	protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;
ER.8	Annex I Part I 2 Point g	process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation);
ER.9	Annex I Part I 2 Point h	protect the availability of essential and basic functions, also after an incident,
ER.9a	Annex I Part I 2 Point h	including through resilience and mitigation measures against denial-of-service attacks;
ER.10	Annex I Part I 2 Point i	minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks;
ER.11	Annex I Part I 2 Point j	be designed, developed and produced to limit attack surfaces,

ID	CRA Reference	Requirement
ER.11a	Annex I Part I 2 Point j	including external interfaces;
ER.12	Annex I Part I 2 Point k	be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;
ER.13	Annex I Part I 2 Point l	provide security related information by recording and monitoring relevant internal activity,
ER.13a	Annex I Part I 2 Point l	including the access to or modification of data, services or functions,
ER.13b	Annex I Part I 2 Point l	with an opt-out mechanism for the user;
ER.14	Annex I Part I 2 Point m	provide the possibility for users to securely and easily remove on a permanent basis all data and settings and,
ER.14a	Annex I Part I 2 Point m	where such data can be transferred to other products or systems, ensure that this is done in a secure manner

7.2 A.2 Essential cybersecurity requirements Part II

Manufacturers of products with digital elements shall:

Table 3: Annex I Part II

ID	CRA Reference	Requirement
VH.1	Annex I Part II 1	identify and document vulnerabilities and components contained in products with digital elements,
VH.1a	Annex I Part II 1	including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the products;
VH.2	Annex I Part II 2	in relation to the risks posed to products with digital elements, address and remediate vulnerabilities without delay,

ID	CRA Reference	Requirement
VH.2a	Annex I Part II 2	including by providing security updates; where technically feasible, new security updates shall be provided separately from functionality updates;
VH.3	Annex I Part II 3	apply effective and regular tests and reviews of the security of the product with digital elements;
VH.4	Annex I Part II 4	once a security update has been made available, share and publicly disclose information about fixed vulnerabilities, including a description of the vulnerabilities, information allowing users to identify the product with digital elements affected, the impacts of the vulnerabilities, their severity and clear and accessible information helping users to remediate the vulnerabilities; in duly justified cases, where manufacturers consider the security risks of publication to outweigh the security benefits, they may delay making public information regarding a fixed vulnerability until after users have been given the possibility to apply the relevant patch;
VH.5	Annex I Part II 5	put in place and enforce a policy on coordinated vulnerability disclosure;
VH.6	Annex I Part II 6	take measures to facilitate the sharing of information about potential vulnerabilities in their product with digital elements as well as in third-party components contained in that product,
VH.6a	Annex I Part II 4	including by providing a contact address for the reporting of the vulnerabilities discovered in the product with digital elements;
VH.7	Annex I Part II 7	provide for mechanisms to securely distribute updates for products with digital elements to ensure that vulnerabilities are fixed or mitigated in a timely manner and,
VH.7a	Annex I Part II 7	where applicable for security updates, in an automatic manner;

ID	CRA Reference	Requirement
VH.8a	Annex I Part II 8	unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital elements, free of charge, accompanied by advisory messages providing users with the relevant information, including on potential action to be taken.

8 Annex B: Application of TR-03183-1

The TR-03183-1 is applied using this rationale:

1. TR-03183-1 provides a comprehensive set of requirements for manufacturers and products that can be used as a basis for the risk assessment and risk treatment and risk treatment required in 6.1.2 and 6.1.3 of this document. Applicable risk acceptance and evaluation criteria based on the intended purpose and foreseeable use of the PwDE are set out in TR-03183-1 5.14.
2. The controls of TR-03183-1 TR-03183-1 Chapter 8 and Chapter 9 are derived for the essential cybersecurity requirements set out in Annex A.1 and A.2 of this document. The application of the controls is performed by filtering the provided control set according to the risk to generate a baseline for the PwDE and an applicability statement of essential cybersecurity requirements set out in 6.1.3 d-1 of this document.
3. TR-03183-1 Chapter 10 refines the requirements of Annex II CRA for user information and can be used to generate appropriate user documentation as set out in 7.5.
4. The TR-03183-1 RH_RT.1.3 establishes requirements for verification of implemented controls in the product design and development process that can be applied to fulfil the requirements of 8.1 of this document.